CASE STUDY

The Trojanized Claude Code Extension on Cursor's Marketplace (October 2026)

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people at risk here were developers who trust their editor to fetch the tools they use every day. For about eleven hours on Thursday 29 October 2026, Cursor's VS Code extension marketplace served a tampered build of the Claude Code extension under its usual name, `Anthropic.claude-code`, as versions 2.1.312 and 2.1.313 for Windows and macOS [1] (**Confirmed**). Cursor states these builds were not developed by Anthropic [1] (**Confirmed**). Anyone who installed or updated to those builds from Cursor's marketplace on macOS or Windows in that window received a loader that profiled the host, planted an attacker SSH key, set up persistence and tried to open a reverse SSH tunnel to an attacker server [1] [2] (**Confirmed**); OSM says it was told victims were compromised during an auto-update of the extension [5] (**Reported**).

The backdoor mostly failed at its last step. Enabling the local SSH service needs administrator rights that the extension lacks on most macOS and Windows hosts, so on those hosts the attacker could not log in through the tunnel; the key, the persistence and the host beacon were still installed or sent [1] (**Confirmed**). Cursor pulled the build, shut its marketplace down, rotated keys, rebuilt it, and had the attacker server taken offline [1] (**Confirmed**). How the attacker got publishing access to Cursor's marketplace has not been published [1] [14] (**Confirmed** for Cursor's notice; **Reported** for the press). No primary names an actor [1] [2] [3] (**Confirmed**).

Key facts at a glance

Field	Value
What	Tampered `Anthropic.claude-code` 2.1.312 and 2.1.313 (win32-x64, darwin-arm64) in Cursor's VS Code Extension Marketplace [1]
Exposure window	About 02:27 to 13:35 PT on 29 Oct 2026, which is 09:27 to 20:35 UTC, about 11 hours [1]; most press is dated 30 Oct
Channel	Cursor's marketplace only; never on the Visual Studio Marketplace or npm [2]; no 2.1.313 on Open VSX, npm or GitHub [4] [6] [7] [8]
Payload	Host and user profiling beacon; attacker SSH key; LaunchAgent, scheduled task or Startup-folder persistence; reverse SSH tunnel [1]
Indicators	134.209.82[.]225 (SSH on TCP 22 as user `tunnel`; HTTP beacon on port 8099); key comment `svc-telemetry`; `com.apple.sysmond.plist`; task `SysMon`; `sysmon.cmd`; `~/.config/.smt` [1]
CVE and KEV	None. No CVE cited by any source; no Cursor or Anthropic entry in KEV catalog 2026.11.10 [9]
Actor	Not named by any primary [1] [2] [3] [4] [5]
Victims	No count in Cursor's current notice [1]; a relayed early figure of "at most 5,000 users" was later removed [5] [13]

Key findings

- **This was a distribution-channel compromise, not a product bug.** Microsoft says the package never reached the Visual Studio Marketplace or npm, and that Anthropic confirmed its own systems were not compromised [2] (**Confirmed**).
- **The version number does not tell clean from malicious.** 2.1.312 is a legitimate Anthropic release of 27 October and also a malicious Cursor build, so only the per-platform VSIX hash and the host artifacts separate them [1] [6] [8] (**Inferred**).
- **No click was needed.** The loader is a function prepended to the extension's main script that runs when the editor loads it, before activation [3] (**Demonstrated**).
- **Admin-rights requirements and coding errors blunted the backdoor.** Cursor says the SSH step fails on most macOS and Windows hosts without admin rights [1] (**Confirmed**). On macOS the Remote Login check fails without admin rights and the enable step is skipped; the Windows setup is routed through a Unix shell; on Linux a crontab flaw can wipe existing user cron jobs [3] (**Demonstrated**). Phorion warns these limits are no defense on a host where Remote Login is already on or is turned on later [3] (**Demonstrated**).
- **Uninstalling is not remediation.** The persistence scripts run outside the extension directory [1] [2] (**Confirmed**).

Top recommendations

1. Hunt every Cursor host for the artifacts in Part 2 and search endpoint, network and extension-installation telemetry for Cursor's indicators [1] (**Confirmed** as Cursor's guidance); match installed VSIX files against Cursor's per-platform hashes rather than the version string, since 2.1.312 is also a clean upstream release [1] [8] (**Inferred**).
2. On an affected host: isolate, remove the key, persistence and tunnel processes, consider a rebuild, and rotate credentials from a trusted system [1] (**Confirmed**).
3. Restrict Cursor extensions to approved publishers and set an extension installation cooldown [2] (**Confirmed** as Microsoft's recommendation).
4. Alert on an editor helper process writing `authorized_keys`, a non-Apple process creating a `com.apple.*` LaunchAgent, and SSH sessions with remote port forwarding; check the key fingerprint, not its comment [3] (**Confirmed** as Phorion's guidance).
5. Block outbound SSH from developer workstations to hosts outside an approved list (**Inferred** from the tunnel behavior in [1]).

Scope and method

This brief covers the tampered extension from the legitimate 2.1.312 release on 27 October to the record as it stood on 11 November 2026. It links rather than retells the 2026 developer-tool cases in npm Supply-Chain Attacks and AI Threats 2026. Tradecraft is described at advisory level: no commands, scripts or key material are reproduced, and indicators appear only as Cursor and Microsoft publish them.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Cursor's notice, Microsoft's analysis, the npm, Open VSX and GitHub release records, the KEV catalog, or a researcher's own dated revision note
Reported	Stated by a news outlet, or a statement relayed by one (the X posts by Anthropic staff were not opened)
Demonstrated	Shown by a researcher's own analysis of the sample or the registry records (Phorion, Socket), or by this study's check of the library's ATT&CK, CAPEC and D3FEND data files
Inferred	This study's own reasoning from cited facts, labelled where it appears

Times are UTC unless a source states another zone. Pacific times on 29 and 30 October are daylight time (UTC-7).

Part 1: what happened

Date and time (2026)	Event	Sources	Grade
27 Oct, 18:36:10	Legitimate `@anthropic-ai/claude-code` 2.1.312 published to npm	[6]	Confirmed
27 Oct, 20:24:20	GitHub release v2.1.312	[8]	Confirmed
27 Oct, 20:26:56	Legitimate `anthropic.claude-code` 2.1.312 on Open VSX	[7]	Confirmed
29 Oct, about 09:27 (02:27 PT)	Malicious 2.1.312 and 2.1.313 become available in Cursor's marketplace	[1]	Confirmed
29 Oct (reported 30 Oct)	Ars reports, citing Kevin Beaumont and Phorion, that 2.1.313 appeared through Anthropic's account on Cursor and superseded 2.1.312, and that Cursor extensions auto-update by default	[11]	Reported
29 Oct	OSM says it began investigating after Dean Hardcastle alerted it in real time	[5]	Reported
29 Oct, about 20:35 (13:35 PT)	Window ends: Cursor removes the version, blocks distribution, then shuts the marketplace down, audits access, rotates keys and rebuilds	[1]	Confirmed
29 Oct	Cursor's notice published; its first version named only 2.1.313 and, as relayed, "at most 5,000 users"	[1] [13]	Confirmed (date); Reported (first wording)
30 Oct, 00:12:56	Anthropic publishes 2.1.314 to npm; GitHub release follows at 01:06:26 and Open VSX at 01:07:38	[6] [7] [8]	Confirmed
30 Oct, 05:30	Phorion's first advisory	[3]	Confirmed
30 Oct, 09:13	Phorion corrects the affected marketplace to Cursor	[3]	Confirmed
30 Oct	Socket finds no Open VSX change-feed event for 2.1.313; OSM first names Open VSX, then revises to Cursor	[4] [5]	Demonstrated; Reported
30 Oct	Anthropic staff say on X that Anthropic's systems were not compromised and only Cursor users are affected	[12] [13]	Reported
30 Oct, 18:30 (11:30 PT)	Cursor updates the IOCs and clarifies affected versions [1]; Phorion's revision note records 2.1.312 as added in that update [3]	[1] [3]	Confirmed
30 Oct, 21:09	Ars Technica headline gives "nearly 12 hours"	[11]	Reported
31 Oct, 00:43	Phorion adds 2.1.312	[3]	Confirmed
31 Oct, 01:02:57	Microsoft Threat Intelligence publishes its analysis (URL dated 30 Oct)	[2]	Confirmed

Date and time (2026)	Event	Sources	Grade
31 Oct, 23:00 (9 am AEST 1 Nov)	OSM: Cursor confirmed the marketplace compromise without explaining how, OSM's later queries went unanswered, and the extension was still unavailable on Cursor's marketplace	[5]	Reported
2 Nov	SecurityWeek: Anthropic moved its legitimate extension straight to 2.1.314 to avoid confusion	[15]	Reported
10 Nov	KEV catalog 2026.11.10 (1,779 entries) carries no Cursor or Anthropic entry	[9]	Confirmed
11 Nov	Cursor's notice as opened states no victim count and no root cause	[1]	Confirmed

Discrepancies in the record

- **Duration.** Cursor's window is about 11 hours [1] (**Confirmed**); Anthropic, as relayed, and the Ars headline say close to 12 hours [11] [13] (**Reported**); Microsoft's page relays Cursor's 02:27 to 13:35 PDT window but also says "a few hours" [2] (**Confirmed**).
- **Whose account.** Ars says 2.1.313 was posted through Anthropic's official account on Cursor [11] (**Reported**); Anthropic, as relayed, says an actor used access to Cursor's marketplace to publish a copy it did not build [12] (**Reported**), and Microsoft records Anthropic's confirmation that its systems were not compromised [2] (**Confirmed**).
- **Who found it.** The Register credits Phorion with first spotting it; OSM says its work began with an alert from Dean Hardcastle; THN credits OSM's Jenn Gile and Paul McCarty with disclosure [5] [12] [13] (**Reported**). Phorion's page gives no detection date or method [3] (**Confirmed**).

Part 2: the technical record

Delivery. OSM describes Cursor's marketplace as an internal service that pulls from Open VSX and from Cursor's own storage and serves files through a Cloudflare-hosted CDN; the malicious extension came from Cursor's marketplace [5] (**Reported**). The tampered bundle is the standard extension with an injected, immediately invoked function prepended to the minified `extension.js` [3] (**Demonstrated**), 66 lines by OSM's count, with no install lifecycle scripts declared [5] (**Reported**). Because it runs as soon as the editor's Node runtime loads the file, before `activate`, no user action is needed [3] (**Demonstrated**). OSM was told that victims were compromised during an auto-update of the extension [5] (**Reported**).

Profiling and beacon. The loader collects hostname, username, operating system, architecture, home and working directories, environment variable names, Git email and public IP [1] (**Confirmed**). Phorion reports up to 40 variable names (never values) matching key, token, secret, password and cloud patterns, which tells the operator which hosts hold cloud credentials or tokens [3] (**Demonstrated**). The beacon is an HTTP POST to port 8099, path `/beacon`, with a loopback attempt to `127.0.0.1:8099` [1] (**Confirmed**).

Access and persistence. The loader tries to add an attacker key, commented `svc-telemetry`, to `authorized_keys`, enable the local SSH service, and open a reverse SSH tunnel to 134.209.82[.]225 on TCP 22 as user `tunnel` [1] (**Confirmed**). It persists through a macOS LaunchAgent (`com.apple.sysmond.plist`), or on Windows a scheduled task (`SysMon`) that requests SYSTEM with a Startup-folder fallback (`sysmon.cmd`),

and retries about every 60 seconds; `~/.config/.smt` is among the artifacts [1] (**Confirmed**). Cursor's indicator list also names a Linux cron @reboot entry and `/tmp/.stk_*` files, and Microsoft maps cron persistence [1] [2] (**Confirmed**); Cursor lists no Linux package as affected [1] (**Confirmed**).

Why most hosts were spared the login. Cursor says enabling SSH needs admin rights the extension lacks on most macOS and Windows hosts [1] (**Confirmed**). Phorion shows the macOS Remote Login check runs unprivileged, gets an administrator-access error instead of "Off", and skips the enable step [3] (**Demonstrated**). Phorion warns these limits are not a defense if Remote Login is on or is turned on later [3] (**Demonstrated**).

Indicator class	Values as Cursor and Microsoft publish them	Sources
Network	134.209.82[.]225: SSH on TCP 22 as `tunnel`; HTTP POST to port 8099 `/beacon`; loopback 127.0.0.1:8099	[1]
Files	Modified `extension.js` SHA-256 `ecb58cb29078d9646ad1dcdbe51526f2d9cfea06be5fb2ab183e8ecc3ab6bf15`; per-platform VSIX hashes for 2.1.312 and 2.1.313 (darwin-arm64, win32-x64) in [1]; decoded tunnel private-key file hash in [2]	[1] [2]
Host	Key comment `svc-telemetry`; `~/.config/.smt`; LaunchAgent `com.apple.sysmond.plist`; scheduled task `SysMon`; Startup file `sysmon.cmd`	[1]
Defender antivirus	Trojan:MacOS/SmtShellMal.A; Trojan:JS/CredTheft.MS!MTB; Trojan:MacOS/MalPlistSysmond.A; HackTool:MacOS/RevAnthShell.A	[2]

Part 3: who and why

No primary names an actor. Cursor names none, Microsoft says its ATT&CK mappings describe implemented or attempted code behavior and do not attribute the activity, Phorion states none, OSM says identity and infrastructure ownership are unverified, and Socket ties it to no earlier campaign [1] [2] [3] [4] [5] (**Confirmed**). The record supports no motive beyond what the code does: find credential-rich developer hosts and keep a way back in [1] [3] (**Inferred**).

What is not linked. OVHcloud CLI release archives were swapped for up to 94 minutes on 19 October, and OSM's own inference ties that account to GlassWorm [17] (**Reported**). No opened source links that event to this one: Socket's analysis does not mention it [4], and The Hacker News notes it only as an event a little over a week earlier [13] [17], so this study asserts no link (**Inferred**).

Part 4: impact and response

Victims. Cursor users who installed or updated to the affected builds from Cursor's marketplace inside the window on Windows (win32-x64) or macOS (darwin-arm64) [1] (**Confirmed**); no primary gives a sector breakdown beyond developers using Cursor (**Inferred**). Cursor's current notice states no count and does not mention direct notification; questions go to `security@cursor.com` [1] (**Confirmed**). The first statement was relayed as "at most 5,000 users" with a promise to contact them directly [13] (**Reported**); OSM says the figure has since been removed from Cursor's notice and suspects the true number is higher, for example through uncounted CDN cache hits, which is speculation [5] (**Reported**). THN quotes Cursor's first statement as impacting at most 5,000 users [13], and Socket and OSM also tie the figure to Cursor [4] [5], while SecurityWeek attributes the estimate to Kevin Beaumont [15] (**Reported**). Microsoft gives no count [2] (**Confirmed**).

Cursor. It publishes platform checks, remediation scripts and IOCs [1] (**Confirmed**).

Anthropic and the registries. The registry records show no 2.1.313 anywhere upstream: npm's versions and time map lack it [6], Open VSX returns "Extension not found" [7], and the GitHub tag returns 404 while releases run from v2.1.312 to v2.1.314 with no incident notice [8] (**Confirmed**). Socket's review of 3,392 Open VSX change-feed events found every platform build of 2.1.312 and 2.1.314 and none of 2.1.313, while briefly published versions of other extensions left both events, though absence cannot rule out every short-lived event [4] (**Demonstrated**). Socket also suspected that a screenshot in OSM's first report showing 2.1.313 as latest was edited or illustrative [4] (**Reported**).

Government and regulator record. No CVE was cited by any source and KEV has no entry [9] (**Confirmed**). The Hub feed rows for this event are vendor and news rows only [10] (**Inferred** from the index). CISA, NCSC and CERT-EU sites were not checked, and no regulator filing was located.

Part 5: the defender and vulnerability-management view

A vulnerability programme keyed on CVE and version will not see this. There is no CVE, no KEV due date and no fixed version to chase, and the affected version string is shared with a clean release [1] [6] [9] (**Inferred**). The work is asset inventory of editor extensions by source marketplace and hash, then host hunting [1] (**Inferred**).

Control	Where it meets the record
Inventory extensions by marketplace and VSIX hash	2.1.312 is both clean and malicious [1] [8]
Approved-publisher allowlist and install cooldown in Cursor	Microsoft's recommendation [2]
File telemetry on editor helpers writing `authorized_keys`; process-only rules miss it	Phorion's detection guidance [3]
Alert on non-Apple processes creating `com.apple.*` LaunchAgents, new scheduled tasks and Startup files	Persistence artifacts [1] [3]
Detect SSH with remote port forwarding and localhost logins with the planted key	Tunnel design [1] [3]

Control	Where it meets the record
Egress control on workstation SSH (**Inferred**)	Reverse tunnel to TCP 22 [1]
Rotate credentials from a clean system; treat env-var names as a target list	Beacon contents [1] [3]
Back up user crontabs before cleanup on Linux (**Inferred**)	Crontab flaw [3]

Microsoft Defender for Endpoint alerts that cover the chain include suspicious activity from a code editor, SSH key addition, launchctl activity, scheduled tasks, plist changes and SSH tunneling [2] (**Confirmed**). Yash Kadakia of Security Brigade, quoted by CSO, calls an extension marketplace another software supply chain and recommends publisher verification, allowlisting, controlled updates and restrictions on outbound connections [16] (**Reported**).

What is overstated and what is understated

- **Overstated:** "nearly 12 hours" against Cursor's roughly 11 [1] [11]; early claims that npm, Open VSX or the VS Code Marketplace served the build, which Microsoft's statement rules out for the Visual Studio Marketplace and npm [2] (**Confirmed**) and the registry records weigh strongly against for Open VSX [4] [6] [7] (**Demonstrated**); and "Anthropic's official account", where Anthropic and Microsoft place the access at Cursor [2] [11] [12] (**Reported**). The SSH backdoor sounds worse than it worked on most hosts [1] [3] (**Confirmed**).
- **Understated:** the affected versions, since the first notice named only 2.1.313 [1] [13]; the victim count, which no primary now gives [1] [5]; the beacon, which still told the operator which hosts hold credentials [3]; and the Linux side effect on cron jobs [3] (**Demonstrated** for Phorion's points, **Reported** for the first wording).

MITRE mappings

This Part binds the verified record to ATT&CK v20.0 Enterprise, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files, and every technique id has a page under `/mitre/techniques/` [18] (**Demonstrated**). Microsoft maps T1098.004, T1572, T1053.003 and T1053.005 [2] (**Confirmed**); the other rows are this study's mapping of confirmed behavior (**Inferred**). Developer workstations are not industrial control systems and no source describes an ICS effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

No group, software or campaign object is bound, because no source names an actor or a malware family [1] [2] [5] (**Confirmed**). ATT&CK carries S9010 GlassWorm, but no opened source links GlassWorm to this event [4] [13] [17], and C0062 Anthropic AI-orchestrated Campaign records an actor manipulating Claude Code in September 2025, not tampering with its distribution [18] (**Demonstrated**). Neither is bound.

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1195.001	Compromise Software Dependencies and Development Tools	Initial Access	Tampered IDE extension in Cursor's marketplace (29 Oct)	[1] [2]
T1608.001	Upload Malware	Resource Development	Malicious builds uploaded to the marketplace (29 Oct)	[1]
T1176.002	IDE Extensions	Persistence	Loader runs inside the editor's extension host on load (29 Oct)	[1] [3]
T1059.007	JavaScript	Execution	Injected function in `extension.js` (Phorion, 30 Oct)	[3] [5]
T1082	System Information Discovery	Discovery	Hostname, OS, architecture, directories, env var names (29 Oct)	[1] [3]
T1033	System Owner/User Discovery	Discovery	Username and Git email (29 Oct)	[1]
T1016	System Network Configuration Discovery	Discovery	Public IP collected (29 Oct)	[1]
T1071.001	Web Protocols	Command and Control	HTTP POST beacon to port 8099 (29 Oct)	[1]
T1041	Exfiltration Over C2 Channel	Exfiltration	Host profile sent in the beacon (29 Oct)	[1] [2]
T1098.004	SSH Authorized Keys	Persistence, Privilege Escalation	`svc-telemetry` key added (29 Oct; Microsoft, 31 Oct)	[1] [2]
T1572	Protocol Tunneling	Command and Control	Reverse SSH tunnel to TCP 22 (29 Oct; Microsoft, 31 Oct)	[1] [2]
T1543.001	Launch Agent	Persistence, Privilege Escalation	`com.apple.sysmond.plist` (29 Oct)	[1] [2]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	`SysMon` task requesting SYSTEM (29 Oct; Microsoft, 31 Oct)	[1] [2]
T1053.003	Cron	Execution, Persistence, Privilege Escalation	Microsoft's mapping; Phorion's Linux crontab flaw (30 Oct)	[2] [3]
T1547.001	Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	`sysmon.cmd` Startup fallback (29 Oct)	[1]
T1036.004	Masquerade Task or Service	Stealth	System-monitor names `SysMon` and `com.apple.sysmond` (29 Oct)	[1] [3]
T1021.004	SSH	Lateral Movement	Intended login through the tunnel, blocked on most macOS and Windows hosts (29 Oct)	[1] [3]

Fit notes (**Inferred**): T1176.002 sits under Persistence in ATT&CK, while here the extension is mainly the delivery route. T1036.004 classifies the artifact names, which the sources report without calling them masquerading. T1021.004 records attempted behavior that the sources say mostly failed. Microsoft's own caveat applies to every row: the mappings describe implemented or attempted code, not confirmed execution on every host [2] (**Confirmed**).

CWE and CAPEC

No CWE is bound, because no opened source cites a CVE and the KEV catalog has no Cursor or Anthropic entry [9] (**Confirmed** for the sources opened). The closest class, CWE-506 Embedded Malicious Code, is noted as this study's reading and not bound (**Inferred**).

CAPEC	Name	Via	Where it meets the record
CAPEC-442	Infected Software	T1195.001	The tampered extension bundle [1] [3]
CAPEC-670	Software Development Tools Maliciously Altered	T1195.001	A coding assistant's editor extension altered [1]
CAPEC-564	Run Software at Logon	T1543.001	The LaunchAgent [1]
CAPEC-504	Task Impersonation	T1036.004	`SysMon` and `com.apple.sysmond` names [1] (**Inferred** fit)

The library relates each CAPEC entry above to the technique in its "Via" column [18] (**Demonstrated**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Technique the library maps it to (from this study)	Where it meets the record
Software Inventory, Software Update, Restore Software	T1195.001	Extension inventory by hash; Cursor's rebuilt marketplace [1]
Outbound Traffic Filtering, Network Traffic Filtering, Remote Terminal Session Detection	T1572	Reverse SSH tunnel [1]
File Integrity Monitoring, File Eviction	T1543.001	LaunchAgent detection and removal [1] [3]
System Daemon Monitoring, Process Termination	T1053.005	Scheduled task and tunnel processes [1]
Scheduled Job Analysis	T1036.004	Masquerading task names [1]

The library maps no D3FEND countermeasure to T1098.004, T1176.002 or T1053.003, so the `authorized_keys` hunt and the extension allowlist have no D3FEND row here [18] (**Demonstrated**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/cursor-extension-trojan-2026.json` (open in Navigator). Scores: 75 for behavior in Cursor's notice or Microsoft's analysis; 50 for behavior known from researcher analysis of the sample; 25 for an inexact fit or behavior that mostly failed. Each technique's comment names its source numbers.

Cross-cutting themes

- **The developer machine is the soft target.** npm Supply-Chain Attacks records a 2026 malicious VS Code extension as the publish-access vector in the Red Hat Cloud Services wave of 29 May to 1 June [19] (**Confirmed**); here the extension was the payload itself (**Inferred**).
- **Registries cannot vet at publish pace.** AI Threats 2026 already recommends IDE extension allowlists, version pinning and hunting for SSH persistence [19] (**Confirmed**); this incident fits that advice point for point (**Inferred**).
- **Trust follows the name, not the channel.** As with SolarWinds SUNBURST and the XZ Utils backdoor, tampered code arrived under a legitimate identity through a trusted channel (**Inferred**). A marketplace that redistributes another publisher's software inherits the job of authenticating that publisher, as OSM argues [5] (**Reported**).
- **Early reporting misnames the channel.** Three registries were blamed before the records cleared them [4] [14] (**Reported**); Hugging Face Supply Chain shows the same limits of registry trust (**Inferred**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Cursor, security notice: malicious Anthropic.claude-code 2.1.312 and 2.1.313 in the Cursor VS Code Extension Marketplace, 29 Oct 2026, updated 30 Oct 11:30 PT	cursor.com/blog/claude-code-extension-security-notice	2026-11-11	Confirmed
2	Microsoft Threat Intelligence, Inside a malicious Claude Code-branded extension and its persistent SSH backdoor, published 31 Oct 2026 01:02 UTC	microsoft.com/en-us/security/blog/2026/10/30/...	2026-11-11	Confirmed
3	Phorion, Official Claude Code extension compromise: security advisory, 30 Oct 2026, revised 31 Oct	phorion.io/blog/offical-claude-code-vsx-compromise/	2026-11-11	Demonstrated (revision history Confirmed)
4	Socket, Claude Code extension compromise, 30 Oct 2026	socket.dev/blog/claude-code-extension-compromise	2026-11-11	Demonstrated
5	OpenSourceMalware, Trojanized Claude Code extension plants persistent SSH backdoor, 30 Oct 2026, updated 1 Nov	opensourcemalware.com/blog/trojanized-claude-code-extension-...	2026-11-11	Reported
6	npm registry metadata, `@anthropic-ai/claude-code`	registry.npmjs.org/@anthropic-ai%2fclaude-code	2026-11-11	Confirmed
7	Open VSX API, `anthropic/claude-code` 2.1.312, 2.1.313 and 2.1.314; the version path `open-vsx.org/api/anthropic/claude-code/2.1.313` answers HTTP 404 "Extension not found", so the link goes to the extension's API root	open-vsx.org/api/anthropic/claude-code	2026-11-11	Confirmed
8	GitHub, anthropics/claude-code releases	github.com/anthropics/claude-code/releases	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
9	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
10	Team Star Wolf Intelligence Hub feed (rows dated 29 Oct to 11 Nov 2026)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed (as data)
11	Ars Technica (Dan Goodin), Anthropic VS Code extension on Cursor backdoored for nearly 12 hours, 30 Oct 2026	arstechnica.com/security/2026/10/...	2026-11-11	Reported
12	The Register, Anthropic: that Claude Code extension compromise couldn't be us, 30 Oct 2026	theregister.com/cyber-crime/2026/10/30/...	2026-11-11	Reported
13	The Hacker News, official Claude Code VS Code extension, 30 Oct 2026	thehackernews.com/2026/10/official-claude-code-vs-code-extension.html	2026-11-11	Reported
14	BleepingComputer, Malicious Claude Code extension on Cursor planted SSH backdoors, 30 Oct 2026	bleepingcomputer.com/news/security/malicious-claude-code-extension-...	2026-11-11	Reported
15	SecurityWeek, Malicious Claude Code extension served in Cursor supply chain attack, 2 Nov 2026	securityweek.com/malicious-claude-code-extension-...	2026-11-11	Reported
16	CSO Online, Cursor removes malicious Claude Code extension after SSH backdoor attempt, 2 Nov 2026	csoonline.com/article/4243210/...	2026-11-11	Reported
17	The Hacker News, OVHcloud CLI release tampering, Oct 2026	thehackernews.com/2026/10/hackers-hijack-five-ovhcloud-cli.html	2026-11-11	Reported
18	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
19	TeamStarWolf case studies: npm Supply-Chain Attacks and AI Threats 2026	/case-studies/NPM_SUPPLY_CHAIN_ATTACKS.md	2026-11-11	Confirmed

Not opened, so not cited as sources: the X posts by Cursor, Felix Rieseberg and David Dworken (used only as relayed by [12] and [13]); Cursor's published check and remediation scripts; and the CISA, NCSC and CERT-EU sites.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Case studies: npm Supply-Chain Attacks, AI Threats 2026, The TeamPCP Supply-Chain Campaign of 2026, XZ Utils Backdoor 2024, SolarWinds SUNBURST, Hugging Face Supply Chain, The Year 2026 in Intrusions, Timeline
- Threat Actors, Malware Families, Notable Incidents, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Supply Chain Security, AI Security Reference, Threat Hunting Reference, Incident Response Reference
- Software and campaigns: S9010 GlassWorm and C0062 Anthropic AI-orchestrated Campaign (context, not bound)
- Techniques: T1195.001 Compromise Software Dependencies and Development Tools, T1608.001 Upload Malware, T1176.002 IDE Extensions, T1059.007 JavaScript, T1098.004 SSH Authorized Keys, T1572 Protocol Tunneling, T1543.001 Launch Agent, T1053.005 Scheduled Task, T1053.003 Cron, T1547.001 Registry Run Keys / Startup Folder
- CAPEC: CAPEC-442, CAPEC-670, CAPEC-564, CAPEC-504
- Navigator layers, including this study's layer, cursor-extension-trojan-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies